VULNERABILITY ASSESSMENT & REMEDIATION REPORT

CloudExify Cybersecurity Internship — Month 2, Project 4

Prepared by: Aliza Javed

Assessment Date: 1- Sep-2026

Confidential — Authorized Lab / Training Environment

1. Executive Summary

This report documents a structured vulnerability assessment and remediation exercise performed as part of CloudExify Cybersecurity Month 2 — Project 4. The assessment covers network and application security testing, vulnerability identification, severity assessment using the Common Vulnerability Scoring System (CVSS), risk prioritization, business impact analysis, and remediation planning.

The assessment methodology follows six stages: planning, reconnaissance, scanning, enumeration, vulnerability analysis, and reporting. The principal tools specified for the project are Nessus, Burp Suite and custom scripts, supported by manual verification where appropriate.

Because screenshots and live scan exports are being added after the report draft, evidence locations are deliberately marked as placeholders rather than representing unverified results as confirmed findings. Final severity, CVSS values, affected components, and status should be populated from the actual authorized lab results before submission.

2. Assessment Scope

The assessment is limited to systems and applications owned or explicitly authorized for the internship lab. Testing is intended to identify security weaknesses without causing unnecessary disruption. Public or third-party systems are outside scope.

Scope items:
- Authorized lab host(s) and exposed services.
- Authorized web application(s) used for security testing.
- Vulnerability discovery and validation using approved tools.
- Risk analysis, CVSS scoring, business impact, and remediation recommendations.

Out of scope:
- Unrelated public systems.
- Denial-of-service testing.
- Destructive actions or permanent modification of data.
- Testing beyond the authorization boundary.

3. Testing Methodology

A professional vulnerability assessment was organized into the following phases:

1. Planning — define objectives, scope, authorized targets, constraints, and timeline.
2. Reconnaissance — gather information about authorized hosts, ports, and services.
3. Scanning — use Nessus to identify known vulnerabilities and configuration issues.
4. Enumeration — investigate relevant services and application components in greater detail.
5. Vulnerability Analysis — assess exploitability, validate significant findings, assign CVSS severity, and determine business impact.
6. Reporting — document evidence, risk, remediation actions, timeline, and resources.

Testing combines automated discovery with manual review. Automated results are not treated as confirmed vulnerabilities until they are reviewed and, where feasible, manually validated.

4. Tools & Technologies

Tool	Purpose
Nessus	Network vulnerability scanning and vulnerability identification.
Burp Suite	Application traffic inspection and manual web security assessment.
Metasploit	Authorized lab-based vulnerability validation and security testing.
Nmap / reconnaissance utilities	Host, port, service, and version discovery where authorized.
Custom scripts	Supporting repeatable checks, parsing, or assessment tasks.

6. Nessus Vulnerability Assessment

Nessus is used for the project's full network vulnerability scan. Insert the completed scan and actual finding evidence after testing.

ID	Finding	Severity	CVSS	Status
#51192	SSL certificate cannot be trusted	Medium	6.5	Confirmed
#57582	SSL self signed certificate	Medium	6.5	Confirmed
#104347	TLS v-1.0 protocol Detection	Medium	6.5	Confirmed
#157288	TLS v-1.1 deprecated protocol	Medium	6.5	Confirmed
#14272	Netstat portscanner	Info	Risk fac: None	Confirmed

5. Detailed Finding #1

SSL Certificate Cannot Be Trusted

Field	Value
Severity	Medium
CVSS v3.0	6.5
Plugin ID	51192
Type	Remote
Family	General

Description

Nessus reports that the server's X.509 certificate cannot be trusted because the certificate chain may not lead to a recognized certificate authority, may contain an invalid certificate, or may have an unverifiable signature.

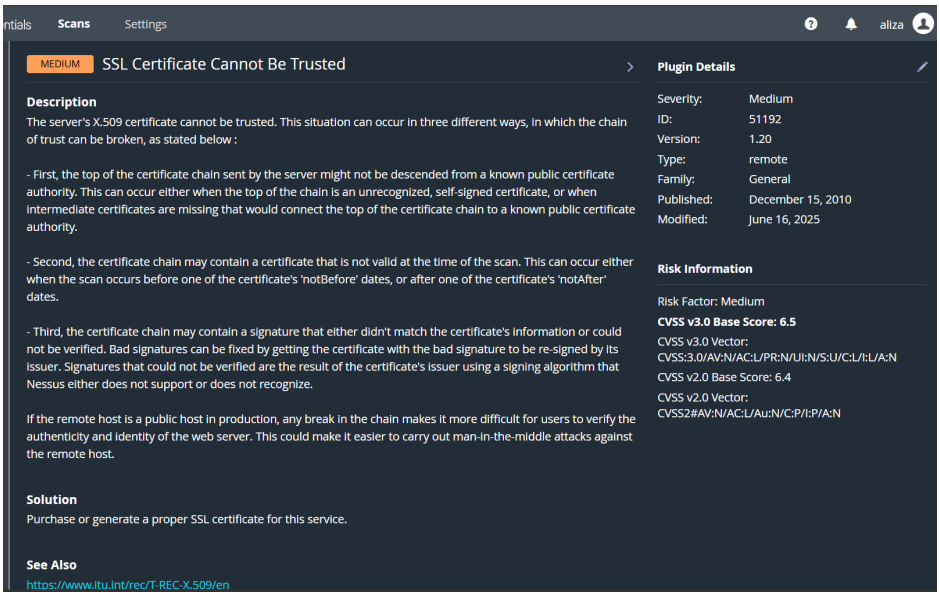
Business Impact

An untrusted certificate can make it harder for users to verify the authenticity of the server and may increase exposure to man-in-the-middle attacks, particularly if the service is used in a production/public environment.

Remediation

Deploy a valid SSL/TLS certificate with a properly trusted certificate chain and ensure intermediate certificates are correctly configured.

Evidence



Finding #2

SSL Self-Signed Certificate

Field	Value
Severity	Medium
CVSS v3.0	6.5
Plugin ID	57582
Type	Remote
Family	General

Description

Nessus reports that the X.509 certificate chain for this service is not signed by a recognized certificate authority. If the remote host is a public host in production, this nullifies the use of SSL as anyone could establish a man-in-the-middle attack against the remote host.

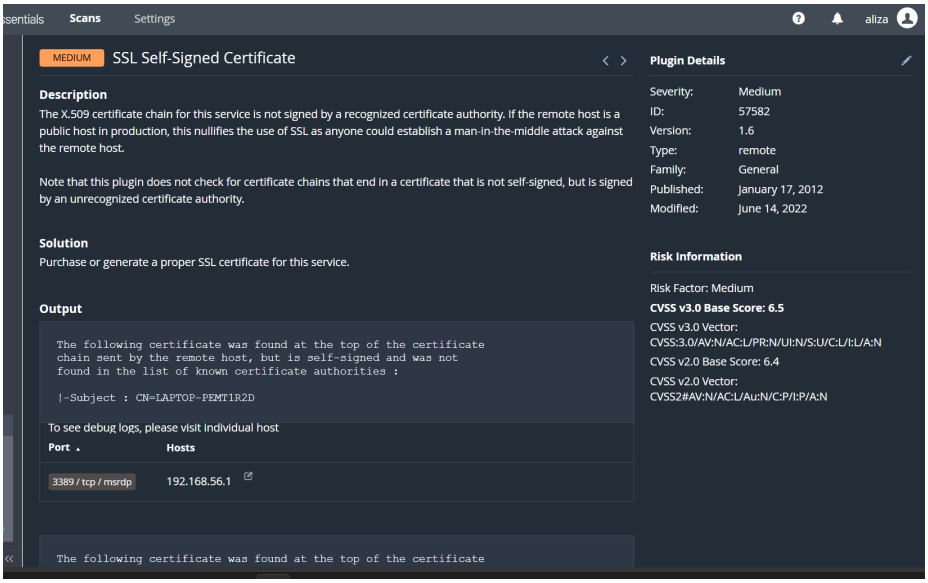
Business Impact

A self-signed certificate may prevent users from properly verifying the authenticity of the server and can increase the risk of man-in-the-middle attacks.

Remediation

Purchase or generate a proper SSL certificate for this service.

Evidence



Finding #2

TLS Version 1.0 Protocol Detection

Field	Value
Severity	Medium
CVSS v3.0	6.5
Plugin ID	104743
Type	Remote

Family	Service detection

Description

Nessus reports that the remote service accepts connections encrypted using TLS 1.0. TLS 1.0 has a number of cryptographic design flaws. Modern implementations of TLS 1.0 mitigate these problems, but newer versions of TLS like 1.2 and 1.3 are designed against these flaws and should be used whenever possible.

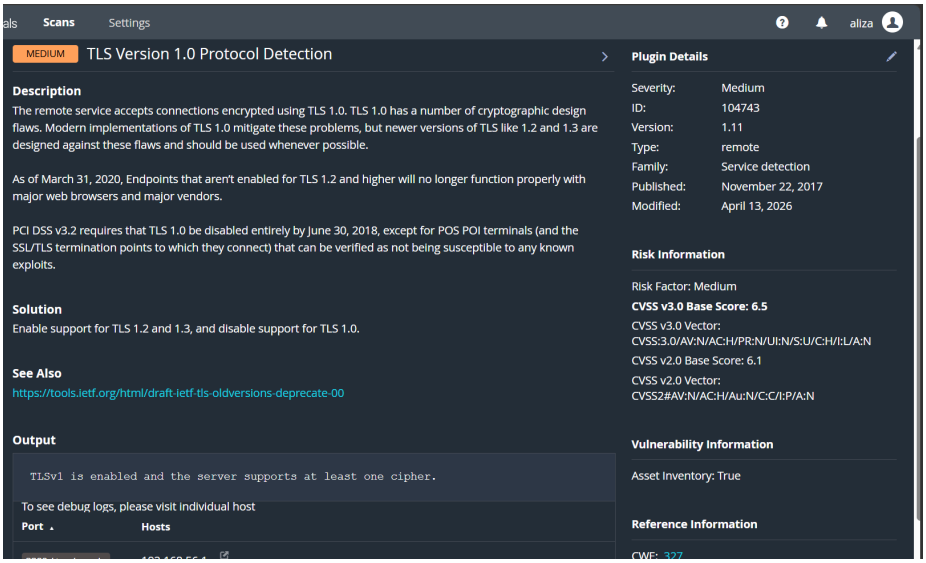
Business Impact

Using TLS 1.0 can expose the service to weaknesses associated with an outdated cryptographic protocol and may result in compatibility and security issues with modern browsers and systems.

Remediation

Enable support for TLS 1.2 and 1.3, and disable support for TLS 1.0.

Evidence



Finding #3

TLS Version 1.1 Deprecated Protocol

Field	Value
Severity	Medium
CVSS v3.0	6.5

Plugin ID	157288
Type	Remote
Family	Service detection

Description

Nessus reports that the remote service accepts connections encrypted using TLS 1.1. TLS 1.1 lacks support for current and recommended cipher suites. Cipher suites that support encryption before MAC computation, and authenticated encryption modes such as GCM, cannot be used with TLS 1.1.

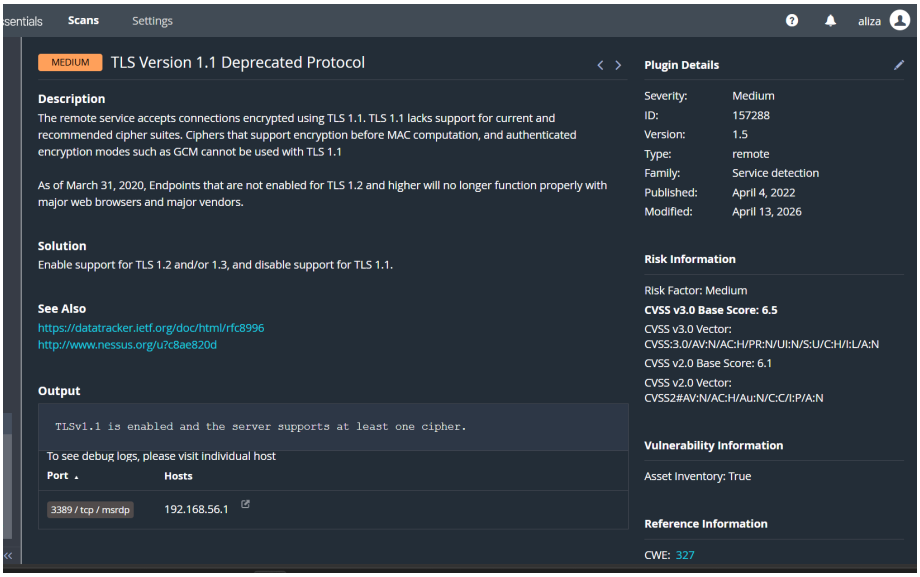
Business Impact

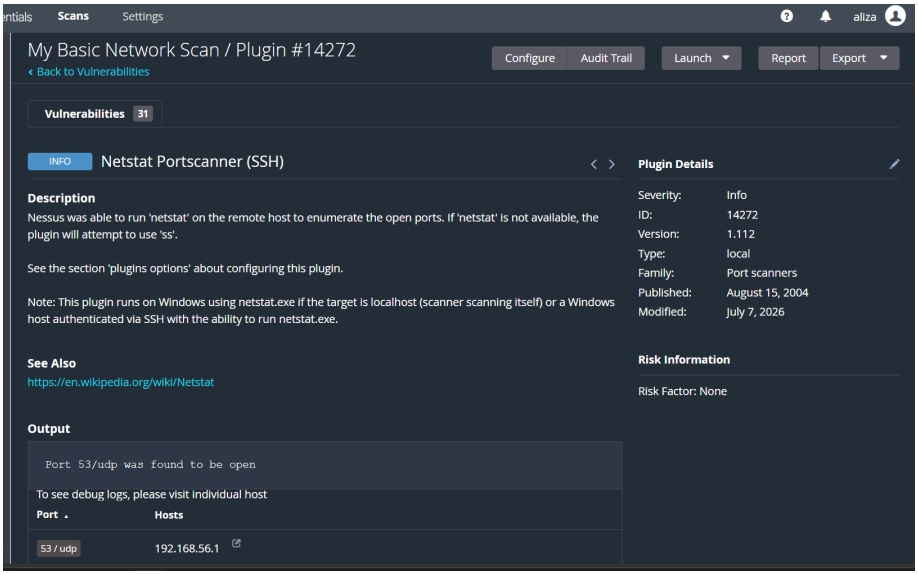
Using TLS 1.1 can expose the service to weaknesses associated with an outdated cryptographic protocol and may result in compatibility and security issues with modern browsers and vendors.

Remediation

Enable support for TLS 1.2 and/or TLS 1.3, and disable support for TLS 1.1.

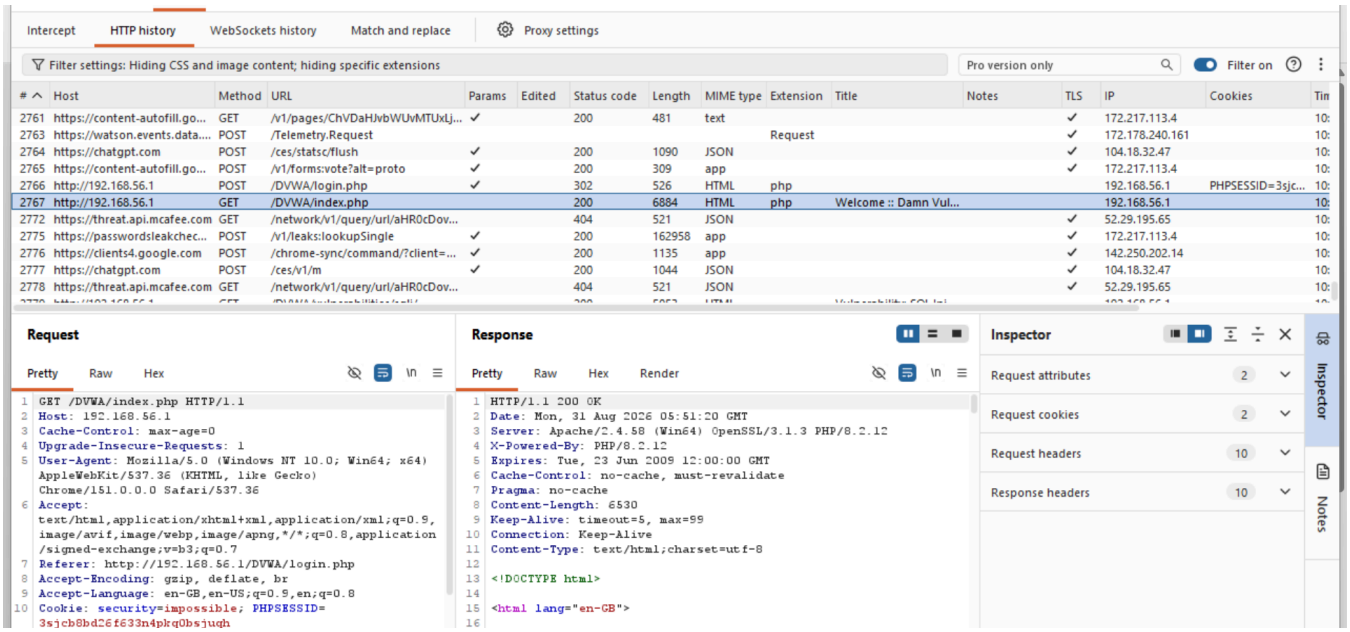
Evidence

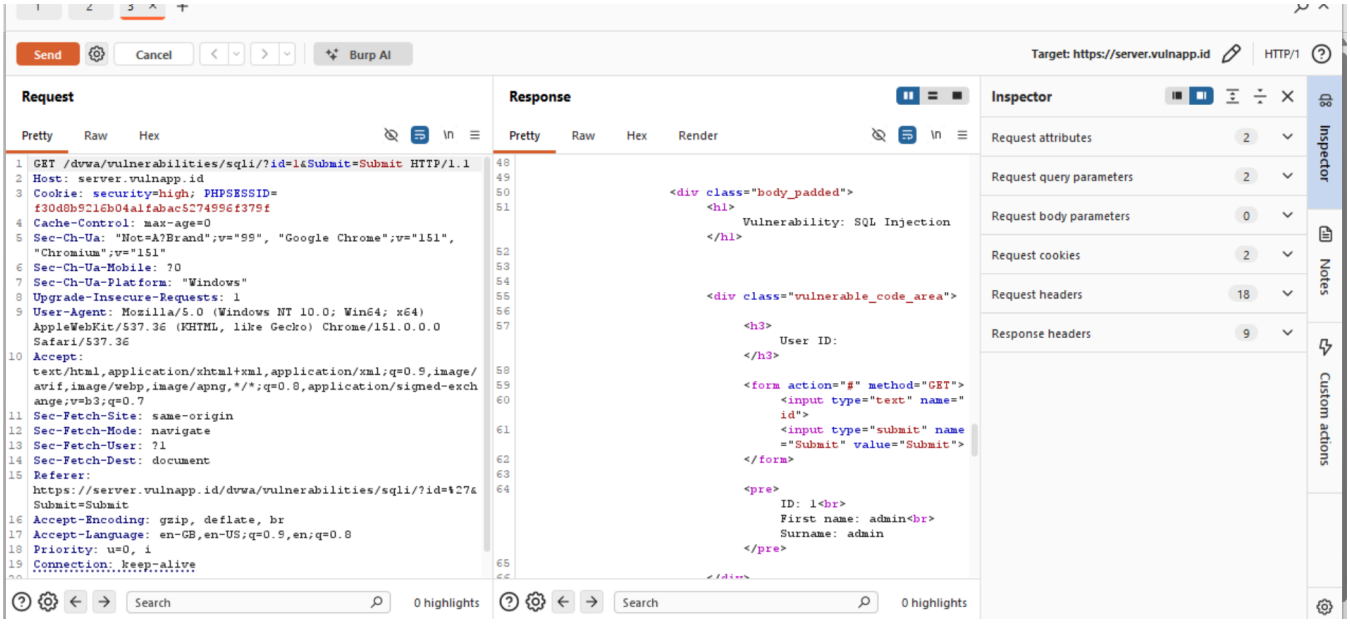




7. Application Security Assessment — Burp Suite

Burp Suite is used to inspect authorized application traffic and manually assess application-level weaknesses.




Send
Cancel
Burp AI
Target: https://server.vulnapp.id
HTTP/1
Request
Pretty
Raw
Hex
GET /dvwa/vulnerabilities/sqli/?id=1&Submit=Submit HTTP/1.1
Host: server.vulnapp.id
Cookie: security=high; PHPSESSID=
f30d8b9216b04a1fabac5274996f379f
Cache-Control: max-age=0
Sec-Ch-Ua: "Not=A?Brand";v="99", "Google Chrome";v="151",
"Chromium";v="151"
Sec-Ch-Ua-Mobile: ?0
Sec-Ch-Ua-Platform: "Windows"
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0
Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/
avif,image/webp,image/apng,*/*;q=0.8,application/signed-exch
ange;v=b3;q=0.7
Sec-Fetch-Site: same-origin
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Referer:
https://server.vulnapp.id/dvwa/vulnerabilities/sqli/?id=%27&
Submit=Submit
Accept-Encoding: gzip, deflate, br
Accept-Language: en-GB,en-US;q=0.9,en;q=0.8
Priority: u=0, i
Connection: keep-alive
Search
0 highlights
Response
Pretty
Raw
Hex
Render

<h1>
Vulnerability: SQL Injection
</h1>

<h3>
User ID:
</h3>
<form action="#" method="GET">
<input type="text" name="
id">
<input type="submit" name
="Submit" value="Submit">
</form>
<pre>
ID: 1
First name: admin
Surname: admin
</pre>
Search
0 highlights
Inspector
Request attributes 2
Request query parameters 2
Request body parameters 0
Request cookies 2
Request headers 18
Response headers 9
Inspector
Notes
Custom actions

9. CVSS Scoring & Justification

CVSS provides a standardized severity rating from 0.0 to 10.0. For this project, the supplied guidance classifies 9.0–10.0 as Critical, 7.0–8.9 as High, 4.0–6.9 as Medium, 0.1–3.9 as Low, and 0.0 as None.

Each final finding should include the CVSS score and a short justification based on the actual vulnerability characteristics, including attack conditions, required privileges, user interaction, scope, and confidentiality, integrity, and availability impact. CVSS values must not be invented before the underlying finding is confirmed.

Finding	CVSS	Severity	Justification
SSL certificate cannot be trusted	6.5	Medium	CVSS v3.0 Vector: AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N
SSL self signed certificate	6.5	Medium	CVSS v3.0 Vector: AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N
TLS v-1.0 protocol Detection	6.5	Medium	CVSS v3.0 Vector: AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N
TLS v-1.1 deprecated protocol	6.5	Medium	CVSS v3.0 Vector: AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N

10. Risk Prioritization

Risk is prioritized using the final validated severity and business impact.
Critical findings receive immediate attention, followed by High, Medium, and Low findings. Prioritization should consider exploitability, exposure, affected assets, data sensitivity, operational impact, and ease of remediation.

Priority	Target Timeline	Typical Action
Critical	0–24 hours	Immediate containment, mitigation, and urgent fix.
High	1–7 days	Prioritized patch/configuration change and verification.
Medium	1–30 days	Schedule remediation and validate closure.
Low	Continuous improvement	Document, monitor, and address through normal hardening.

11. Business Impact Analysis

For each validated finding, describe the potential effect on confidentiality, integrity, availability, operations, reputation, compliance, or data exposure.

Finding	Confidentiality	Integrity	Availability	Business Impact

V-01 – SSL Self-Signed Certificate	Medium	Medium	Low	May allow man-in-the-middle attacks if users cannot properly verify the server certificate, potentially exposing or altering transmitted data.
V-02 – TLS Version 1.0 Protocol Detection	Medium	Medium	Low	Use of deprecated TLS 1.0 may expose encrypted communications to known cryptographic weaknesses and can cause compatibility and compliance issues with modern systems.
V-03 – TLS Version 1.1 Deprecated Protocol	Medium	Medium	Low	Use of deprecated TLS 1.1 may weaken the security of encrypted communications and can result in compatibility and compliance issues with modern browsers and security standards.

12. Remediation Recommendations

Remediation recommendations should be specific and actionable. For each confirmed finding, the technical team should:

- Identify and remove the root cause rather than only hiding the symptom.
- Apply supported patches or upgrade vulnerable software where applicable.
- Disable unnecessary services, ports, protocols, or features.
- Enforce secure configuration and least privilege.
- Validate and sanitize application inputs where relevant.
- Use secure coding controls such as parameterized database queries for injection risks and context-appropriate output encoding for XSS risks.
- Re-test after remediation to verify that the finding is closed.
- Maintain monitoring and periodic vulnerability scanning.

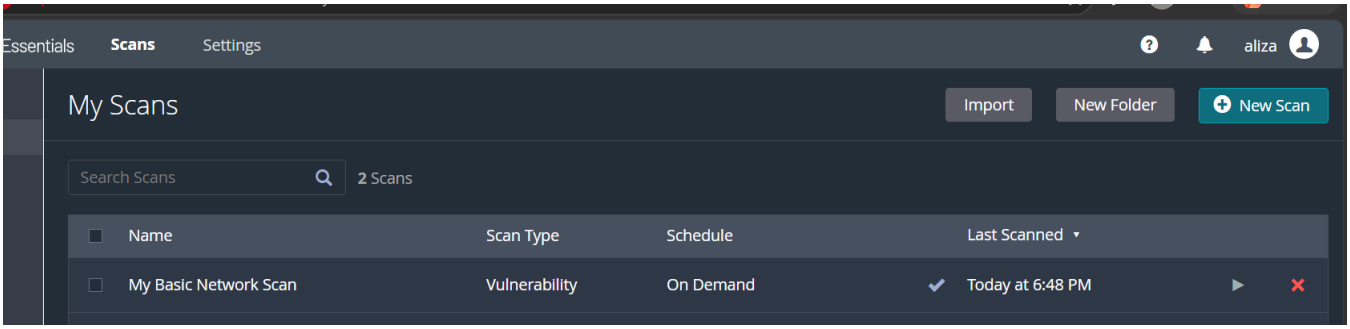
The remediation roadmap follows the supplied project guidance:
Critical: 0–24 hours; High: 1–7 days; Medium: 1–30 days; Low: continuous improvement.

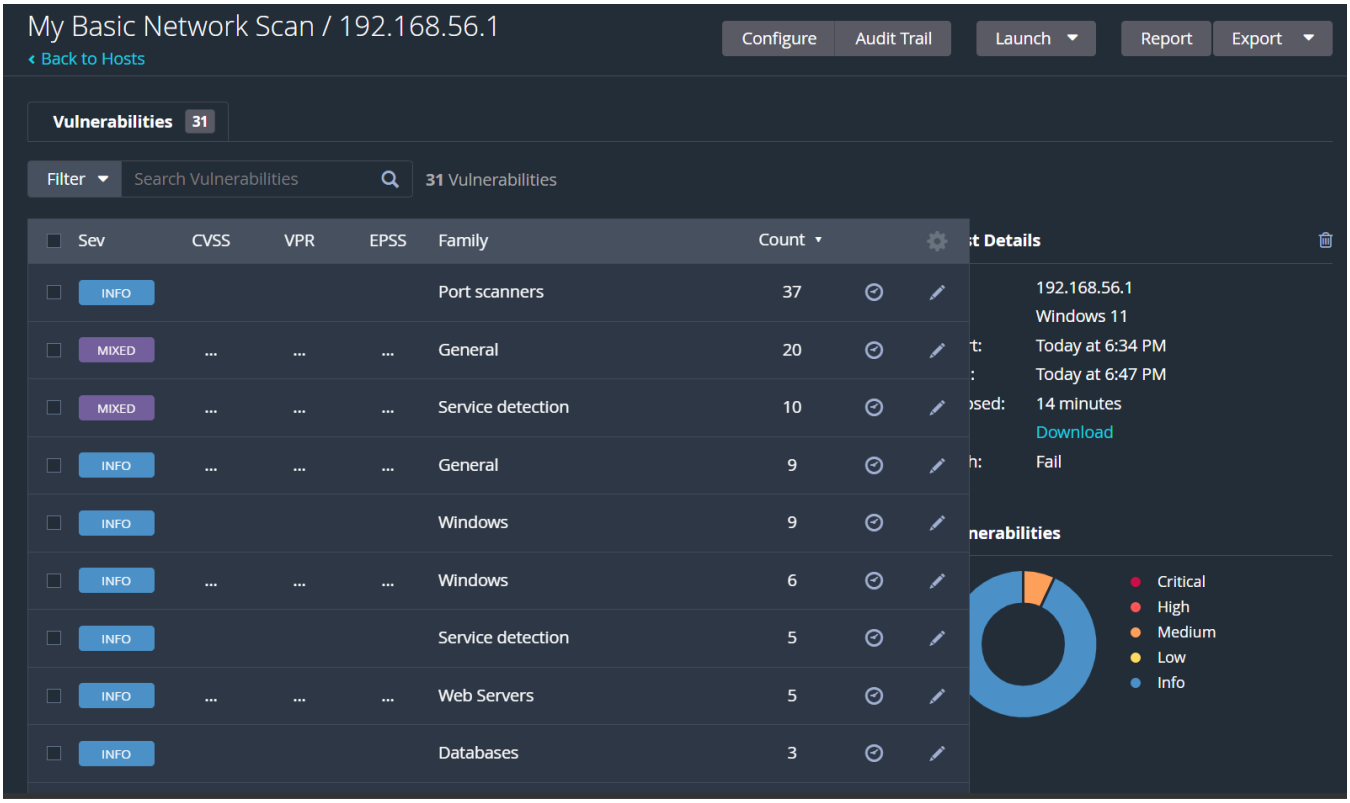
13. Remediation Roadmap

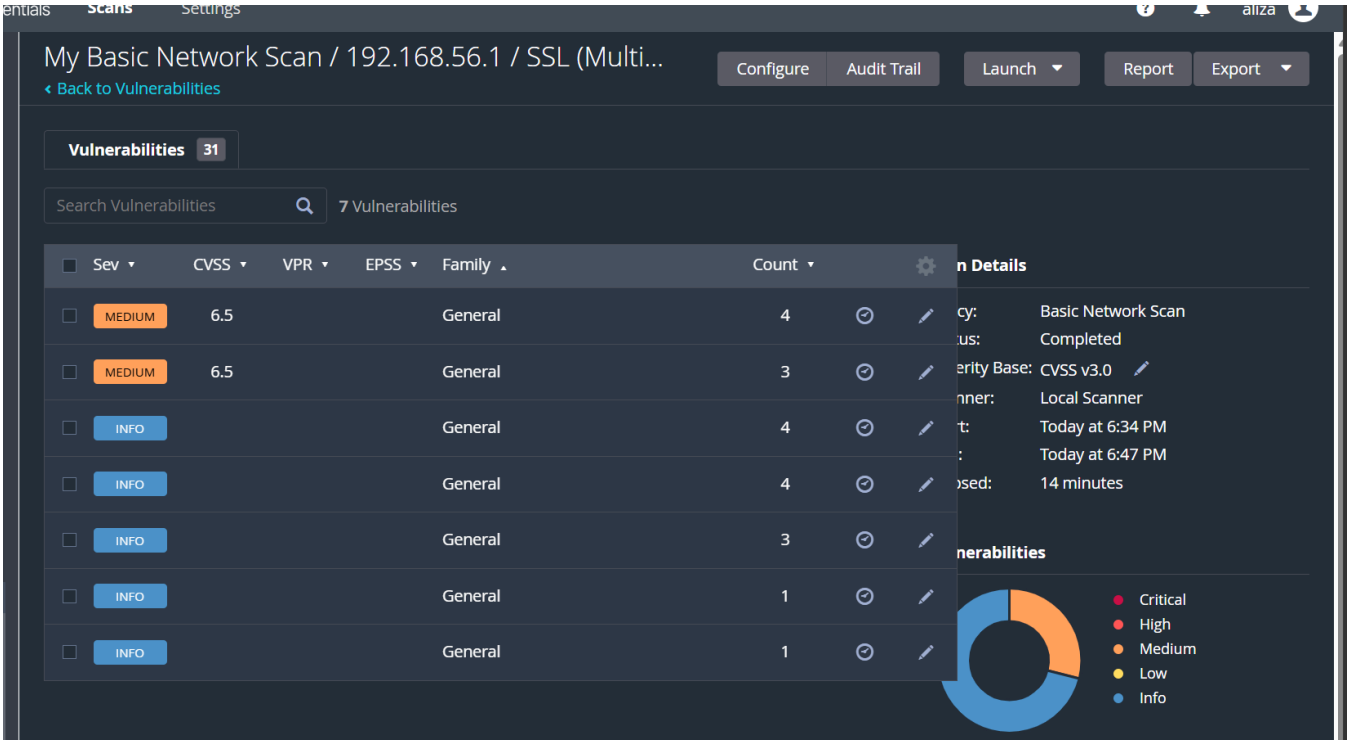
Finding	Priority	Recommended Fix	Owner / Resource	Timeline
V-01	Medium	Replace the self-signed certificate with a valid certificate from a trusted certificate authority and configure the complete certificate chain.	System / Infrastructure Administrator	1–30 days
V-02	Medium	Disable TLS 1.0 and enable TLS 1.2 and TLS 1.3 where supported. Re-test the service after the configuration change.	System / Infrastructure Administrator	1–30 days
V-03	Medium	Disable TLS 1.1 and enable TLS 1.2 and TLS 1.3 where supported. Re-test the service after the configuration change.	System / Infrastructure Administrator	1–30 days

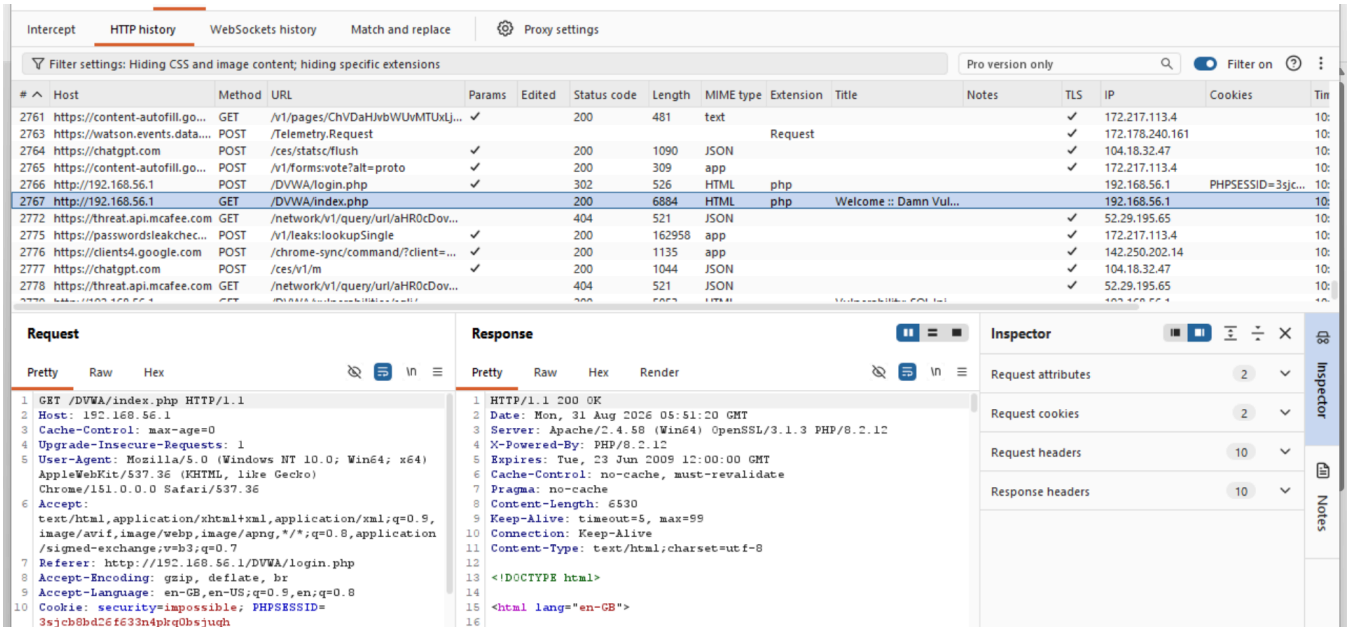
15. Evidence & Appendices

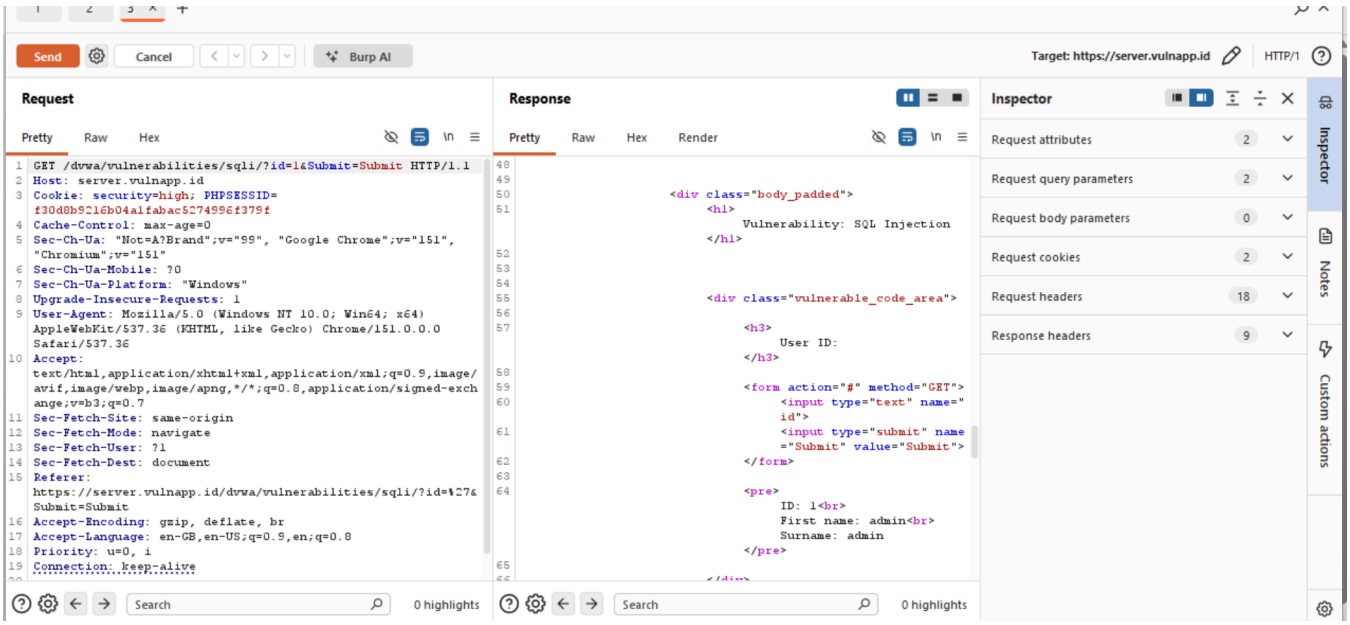
The final report must include actual evidence from the authorized assessment. Insert the following after testing is completed:




My Basic Network Scan / 192.168.56.1
Back to Hosts
Configure
Audit Trail
Launch
Report
Export
Vulnerabilities 31
Filter
Search Vulnerabilities
31 Vulnerabilities
Sev
CVSS
VPR
EPSS
Family
Count
INFO
Port scanners
37
MIXED
General
20
Service detection
10
INFO
General
9
Windows
9
Windows
6
Service detection
5
Web Servers
5
Databases
3
Details
192.168.56.1
Windows 11
Today at 6:34 PM
Today at 6:47 PM
14 minutes
Download
Fail
Critical
High
Medium
Low
Info


My Basic Network Scan / 192.168.56.1 / SSL (Multi...
Back to Vulnerabilities
Configure
Audit Trail
Launch
Report
Export
Vulnerabilities 31
Search Vulnerabilities
7 Vulnerabilities
Sev
CVSS
VPR
EPSS
Family
Count
MEDIUM
6.5
General
4
3
INFO
Details
Basic Network Scan
Completed
CVSS v3.0
Local Scanner
Today at 6:34 PM
Today at 6:47 PM
14 minutes
Critical
High
Medium
Low
Info





16. Scope Limitations

The assessment is dependent on the availability and configuration of the authorized lab environment. Automated scanner results may include false positives or findings that require additional verification. The final report should distinguish between Detected, Manually Validated, False Positive, and Not Tested statuses.

No claim of successful exploitation, unauthorized access, or a specific CVSS score should be made unless supported by the actual evidence collected during the assessment.

17. Conclusion

This assessment establishes a repeatable process for discovering, validating, prioritizing, and remediating security weaknesses. The final security posture should be determined from the completed Nessus results, application testing evidence, manual

validation, and CVSS analysis. High-impact findings should be remediated first and then re-tested to confirm closure. The completed evidence appendix should accompany this report as part of the final submission package.

18. Glossary

Term	Meaning
CVSS	Common Vulnerability Scoring System.
Nessus	Vulnerability scanning platform used for identifying known weaknesses.
Burp Suite	Web application security testing platform for inspecting and modifying HTTP traffic.
Metasploit	Security testing framework used for authorized vulnerability validation.
Vulnerability	A weakness that may affect the security of a system or application.
Remediation	Action taken to remove, reduce, or otherwise address a security risk.